

Security, Privacy, Accessibility & Edge-Case Checklist

Frontend-only does not mean quality-free • defensive client behavior for assessment-grade UX

1. Security boundaries

This is a frontend-only simulation. Client-side validation improves UX but is not a security boundary. Do not claim that the web app is secure because Zod validates input. If a real backend is added later, all validation and authorization must be repeated server-side.

- Do not hard-code real API keys, OTP providers, database credentials or secrets in Vite environment variables.
- Do not store sensitive personal data in localStorage. If persistence is needed for the demo, prefer sessionStorage and store only the minimum draft fields.
- Do not inject user input with dangerouslySetInnerHTML.
- Treat Terms content as static trusted content; sanitize any future remote HTML before rendering.
- Use rel='noopener noreferrer' on external links opened in new tabs.
- Do not log full emails, phone numbers or profile payloads to production console output.

2. Input hardening

- Trim leading/trailing whitespace where semantically safe; reject whitespace-only names.
- Cap all text lengths even when the UI looks constrained.
- Use inputMode rather than relying only on type='number' for numeric UX; type=number permits characters/behaviors that may be undesirable.
- Normalize dependent selections when their parent value changes.
- Prevent double submission while a request is pending.
- Guard against race conditions when users click Back/Next quickly.

3. Edge-case matrix

Case	Expected behavior
Invalid email	Inline error; no verification request.
Offline/simulated network failure	Global banner/toast + retry; retain input.
Rapid double click	One request only; button loading/disabled.
Back after completing a step	Values remain; user can edit; later dependent data revalidates.
Under minimum age	Immediate clear blocking feedback; do not silently continue.
OTP paste	Entire valid code populates cleanly.
Wrong/expired OTP	Contextual error; inputs remain editable; resend path visible.
State changed after city chosen	Clear incompatible city/college and request reselection.
Refresh mid-flow	Either intentionally reset or restore minimal session draft; behavior documented.
Browser autofill	Labels remain readable; validation still runs.
Very narrow screen	No clipped controls or horizontal scroll.
200% zoom	Content remains operable and readable.

4. Accessibility acceptance tests

- Tab order follows the visual order on every step.
- Shift+Tab works backward without focus traps.
- Error text is programmatically associated with its field.
- First invalid field receives focus after submit.
- Progress has text equivalent such as 'Step 2 of 4'.
- Color is never the only error/success indicator.
- Screen-reader announcement is used for async verification/submission outcomes.
- Motion is reduced when the OS/browser preference requests it.

5. Privacy note for the demo

Use obviously synthetic test data in the recording. The reference app's Play listing states that it may collect location and personal information; your assessment should not collect or transmit real user data because no backend is required.

6. Pre-submission security pass

1. Search the repository for API keys, tokens, passwords and accidental personal data.
2. Remove console logs and debug panels.
3. Verify production build does not expose source-only secrets.
4. Test malformed, empty and extremely long input.
5. Test all pending/loading buttons for duplicate actions.
6. Run dependency audit and remove packages you no longer use.